



Module Title

Cybersecurity and Networking

Internship Assignment Submission

OWASP Top 10:2025 Risk Identification

Student Name: Jiwosh Shrestha

Internship ID: JVL-CS-2026-8990

Role: Cybersecurity Intern

Duration: 3 months

Assignment Submission Date: Monday, 28th September 2026

Day:21 (Twenty-One)

Contents

1. A01:2025 BROKEN ACCESS CONTROL	3
1.1 Answer all questions clearly in your own words.	3
1.1.1 PART A — FUNDAMENTALS	3
1.1.2 PART B — ACCESS CONTROL TYPES	5
1.1.3 PART C — OBJECT AUTHORIZATION	6
1.1.4 PART D — SERVER-SIDE SECURITY	7
1.1.5 PART E — ACCESS CONTROL MATRIX	8
1.1.6 PART F — CASE STUDY Fictional scenario:	9

1. A01:2025 BROKEN ACCESS CONTROL

1.1 Answer all questions clearly in your own words.

1.1.1 PART A — FUNDAMENTALS

1. Explain Authentication.

Authentication is the process of verifying who a user is. For example, entering a username and password to login.

2. Explain Authorization.

Authorization checks what an authenticated user is allowed to access or do. For example, checking whether a user can access an admin panel.

3. What is the difference between Authentication and Authorization?

Authentication checks who you are, while Authorization checks what you are allowed to do.

Example: Login verifies your identity (authentication), and access to specific files depends on your permissions (authorization).

4. What is access control?

Access control is a security mechanism that allows or denies users access to resources or actions based on their permissions.

5.What is Broken Access Control?

Broken Access Control happens when an application does not properly enforce permission, allowing users to access information or perform actions they should not be allowed to.

6.What does Least Privilege mean?

Least Privilege means giving users only the permissions they need to perform their required tasks.

7. What does Deny by Default mean?

Deny by Default means access should be denied unless the user has been explicitly given permission.

8.Why is authentication alone not enough to protect sensitive functionality?

Being logged in only proves the user's identity. The system must also check whether the user has permission to perform the requested action.

1.1.2 PART B — ACCESS CONTROL TYPES

9. Explain vertical access control.

Vertical access control separates users with different privilege levels, such as Students and Admins.

10. Give one fictional example of a vertical access control problem.

A student logs into an internship portal and is able to access the Admin User Management page. This is vertical access control problem.

11. Explain horizontal access control.

Horizontal access control separates resources belonging to users with the same level of privilege.

12. Give one fictional example of a horizontal access control problem.

Student A can view Student B's private assignment submission even though both are students. This is horizontal access problem.

13. What is context-dependent access control?

Context dependent access control makes permissions decisions based on the current situation, conditions, or workflow.

14. Give one simple fictional example.

A student can cancel an internship application only while it is still pending. After it is approved, cancellation is not allowed.

1.1.3 PART C — OBJECT AUTHORIZATION

15. What is an object/resource identifier?

An object resource identifier is a value used to identify a specific record or resource, such as profile ID, assignment ID, or document ID.

16. Explain the IDOR concept in your own words.

IDOR occurs when an application uses an object ID but fails to properly check whether the current user is allowed to access that object.

17. Why does knowing a record ID not automatically mean a user is allowed to access it?

An ID only identifies a record. The server must still check whether the user has permission to access that particular record.

18. Why must ownership/permission be checked on the server?

Server-side checks cannot be trusted to the user's browser and are needed to make the final security decision before providing sensitive information or performing an action.

1.1.4 PART D — SERVER-SIDE SECURITY

19. Why is hiding an Admin button in the browser not enough security?

Hiding the button only changes what the user sees. It does not prevent someone from sending a request directly to the server.

20. Explain why authorization checks should be performed in trusted server-side logic. The server controls access to protected resources and can verify the user's identity, permissions, and resource ownership before allowing the requested action.

1.1.5 PART E — ACCESS CONTROL MATRIX

Create an access control matrix for this fictional internship portal.

Resource	Student	Reviewer	Admin
Lessons	ALLOW	ALLOW	ALLOW
Own Submission	ALLOW	DENY	ALLOW WHEN AUTHORIZED
Other Student Submission	DENY	ALLOW ONLY WHEN ASSIGNED	ALLOW WHEN AUTHORIZED
Review Panel	DENY	ALLOW ONLY WHEN ASSIGNED	ALLOW
User Management	DENY	DENY	ALLOW

Explanation of Decisions

1.Lesson- Student: ALLOW

Students need access to lessons as part of the internship portal.

2.Other Student Submission – Student: DENY

A student should not automatically access another student's private submission because they do not own it.

3.Review Panel – Reviewer: Allow only when assigned

A reviewer should access the review panel when they are assigned to review the relevant submissions.

1.1.6 PART F — CASE STUDY Fictional scenario:

Student A is logged into an internship portal. Student A requests Student B's private assignment submission. The server finds Student B's submission and returns it without checking ownership or permission.

Answer:

1. Is Student A authenticated?

Yes, Student A is logged into the internship portal, so the system has verified their identity.

2. Is Student A necessarily authorized to view Student B's submission?

No. Being logged in does not automatically give Student A permission to view another student's private submission.

3. Which security check is missing?

The server is missing an authorization/ownership check to verify whether Student A is allowed to access Student B's submission.

4. Is this primarily a vertical or horizontal access control issue?

It is primarily a horizontal access control issue because Student A and Student B have the same general privilege level, but Student A is accessing Student B's private resource.

5. Which OWASP Top 10:2025 category applies?

The applicable category is A01:2025 – Broken Access Control

6. What is the possible impact?

It could cause unauthorized disclosure of private assignment information and expose confidential student data.

7. Give a high-level defensive recommendation.

The server should verify the logged-in user's permission and ownership before returning the requested submission. Access should be denied if user is not authorized.